

WINDOWS CLI TEMELLERİ

[Kaynak](#)

İÇERİK

1. Windows Komut Satırı Arayüzü: Dosyalarda Gezinme ve İlk Dosyanızı Bulma
2. Windows'ta Sistem Bilgilerini Toplama

Windows Komut Satırı Arayüzü: Dosyalarda Gezinme ve İlk Dosyanızı Bulma

Windows ortamlarında siber güvenlik operasyonları gerçekleştirilirken Grafik Kullanıcı Arayüzü (GUI) yerine doğrudan **Command Prompt (cmd.exe)** veya **PowerShell** gibi komut satırı arayüzlerinin (CLI) tercih edilmesi operasyonel bir zorunluluktur. Terminal kullanımı; sistem üzerinde daha derin ve kısıtlamasız bir kontrol sağlar, grafik arayüzlerin sebep olduğu yavaşlığı ortadan kaldırır ve endüstri standardı güvenlik/sızma testi araçlarının neredeyse tamamının CLI tabanlı çalışması nedeniyle zaruridir. Windows sistem mimarisini anlamak, dosya sisteminde hızlıca gezinmek ve gizlenmiş hedefleri tespit etmek, Windows Enumeration (Sistem Keşfi ve Bilgi Toplama) süreçlerinin temelini oluşturur.

Bir Windows sistemine komut satırı üzerinden ilk erişim sağlandığında (Initial Access), operasyonun bağlamını kavramak adına nerede olduğumuzu kesin olarak bilmemiz gerekir. Linux sistemlerindeki `pwd` komutunun Windows CLI ortamındaki karşılığı, herhangi bir parametre almadan çalıştırılan `cd` (Current Directory) komutudur.

```
C:\Users\Administrator> cd
C:\Users\Administrator
```

Bu komut, kullanıcının o an dosya sistemi hiyerarşisinde tam olarak nerede bulunduğunun mutlak yolunu (Absolute Path) terminale yazdırır. Çıktıdan anlaşıldığı üzere, şu anda **C:** sürücüsü altındaki **Users** dizininde, **Administrator** kullanıcısının profil klasöründe bulunuyoruz. Çalıştırılacak zararlı yüklerin (Payload) veya hedef betiklerin doğru dizinde tetiklenmesi için bu doğrulama adımı atlanamaz.

Mevcut dizinde hangi dosyaların ve klasörlerin bulunduğunu listelemek için `dir` (Directory) komutu kullanılır. Bu adım, sistemin genel yapısını ve potansiyel hedefleri görmek için uygulanan ilk keşif aşamasıdır.

```
C:\Users\Administrator> dir
Volume in drive C has no label.
Volume Serial Number is A1B2-C3D4
```

Directory of C:\Users\Administrator

```
10/24/2024  10:00 AM    <DIR>          .
10/24/2024  10:00 AM    <DIR>          ..
10/24/2024  10:05 AM    <DIR>          Desktop
10/24/2024  10:05 AM    <DIR>          Documents
10/24/2024  10:05 AM    <DIR>          Downloads
              0 File(s)                0 bytes
              5 Dir(s)  20,123,456,789 bytes free
```

Çıktı satır satır incelendiğinde; ilk sütun ögenin oluşturulma/değiştirilme tarihini ve saatini gösterir. <DIR> etiketi, ilgili satırdaki ögenin bir dosya değil, bir dizin (Directory) olduğunu belirtir. En alt satırlarda ise dizindeki toplam dosya sayısı ve diskin boş alanı gibi fiziksel kaynak bilgileri yer alır. Ancak bu standart çıktı, operasyonel bir sızma testi için asla yeterli değildir çünkü yalnızca varsayılan görünürlüğe sahip öğeleri listeler.

ÖNEMLİ: Tehdit aktörleri (Threat Actors) ve zararlı yazılımlar, sistemde kalıcılık (Persistence) sağlamak veya hassas verileri gizlemek amacıyla sıklıkla Windows'un +h (Hidden - Gizli) veya +s (System - Sistem) dosya özniteliklerini (Attributes) kullanır. Bu gizli dosyalar standart dir komutundan kaçır. Görünmeyen saldırı yüzeyini ve gizlenmiş klasörleri ortaya çıkarmak için komuta /a (All Attributes - Tüm Öznitelikler) parametresi eklenmelidir.

```
C:\Users\Administrator> dir /a
Volume in drive C has no label.
```

Directory of C:\Users\Administrator

```
10/24/2024  10:00 AM    <DIR>          .
10/24/2024  10:00 AM    <DIR>          ..
10/24/2024  09:15 AM    <DIR>          AppData
10/24/2024  10:05 AM    <DIR>          Desktop
10/24/2024  10:05 AM    <DIR>          Documents
10/24/2024  08:30 AM                34 NTUSER.DAT
```

Çıktıda standart dir komutunda görünmeyen **AppData** dizini ve kullanıcı yapılandırmalarını tutan kritik **NTUSER.DAT** dosyası (Kayıt defteri hive dosyası) ortaya çıkmıştır. Sadece /a parametresinin kullanılması, sistemdeki gizli yapılandırmaların ve olası zararlı bileşenlerin gözden kaçırılmasını engeller. Eğer sadece gizli dosyaları filtrelemek isteseydik (B Planı), /a:h parametresi ile çok daha spesifik bir arama gerçekleştirebilirdik.

Dosya sistemi içinde gezinmek ve yanal hareketler yapmak için yine cd (Change Directory) komutu, hedef dizin adıyla birlikte kullanılır. Bir alt dizine inmek veya hiyerarşide bir üst dizine (Parent Directory) çıkmak için sistemin mantıksal referansları kullanılır.

```
C:\Users\Administrator> cd Documents
C:\Users\Administrator\Documents> cd ..
C:\Users\Administrator>
```

İlk komut bizi doğrudan **Documents** klasörünün içine sokmuştur. Prompt'un (Komut satırı imleci) güncellenmesiyle dizin değişimi anında doğrulanır. İkinci komutta kullanılan `..` (Çift nokta) referansı ise sistemi bulunduğumuz klasörden bir üst seviyeye (Yani tekrar Administrator klasörüne) geri fırlatır.

Büyük Windows dosya sistemlerinde, konumu bilinmeyen spesifik bir dosyayı (örneğin görev dosyamız olan **task_brief.txt**) klasör klasör gezerek manuel aramak zaman kaybıdır. Bunun yerine, Windows'un kendi içinde gelen güçlü arama dinamiklerini tetikleyen `/s` (Subdirectories) parametresi `dir` komutuna eklenerek özyineli (Recursive) bir arama başlatılır.

```
C:\Users\Administrator> dir /s task_brief.txt
Volume in drive C has no label.

Directory of C:\Users\Administrator\AppData\Local\Temp\hidden_missions

10/25/2024  11:00 AM                150 task_brief.txt
                1 File(s)                150 bytes

Total Files Listed:
                1 File(s)                150 bytes
```

Bu komut, bulunduğumuz dizinden (Administrator) başlayarak altındaki binlerce klasör ve alt klasör ağacını otomatik olarak tarar. Çıktı, hedefin tam olarak

`C:\Users\Administrator\AppData\Local\Temp\hidden_missions` dizini içine saklandığını kesin olarak ortaya çıkarmıştır. Bu yöntem, Linux'taki `find` komutunun Windows ortamındaki doğrudan operasyonel karşılığıdır ve konfigürasyon dosyaları, şifre metinleri veya flag bulma süreçlerinde hayati önem taşır.

Hedefin fiziksel konumunu tespit ettikten sonra, hedef dizine navigasyon gerçekleştirip dosya içerisindeki veriyi dışarı aktarmamız (Data Extraction) gerekir. Windows CLI ortamında metin tabanlı dosyaların içeriğini doğrudan terminalin Standart Çıktısına (stdout) basmak için `type` komutu kullanılır.

```
C:\Users\Administrator> cd AppData\Local\Temp\hidden_missions
C:\Users\Administrator\AppData\Local\Temp\hidden_missions> dir
10/25/2024  11:00 AM                150 task_brief.txt

C:\Users\Administrator\AppData\Local\Temp\hidden_missions> type
task_brief.txt
Tebrikler! Dosya sisteminde özyineli arama yapmayı ve gizli dizinlerdeki
```

hedeflere

ulaşmayı başardın. Bir sonraki görevin, üzerinde bulunduğun sistemin ağ ve mimari yapılandırmalarını analiz etmektir.

Saldırı zincirimiz şu mantıkla ilerlemiştir: Önce `cd` ile hedefin bulunduğu derin dizine geçiş yapılmış, `dir` ile hedefin o anki varlığı doğrulanmış ve son olarak `type` komutu ile dosyanın içeriği ekrana dökülmüştür. `type` komutu, Linux'taki `cat` komutunun işlevini yerine getirir.

DİKKAT (B Planı): Eğer okumaya çalıştığımız dosya devasa boyutta bir log veya veritabanı dökümü olsaydı, `type` komutu tüm içeriği saniyeler içinde ekrandan akıtıp geçecekti. Böyle bir durumda komut çıktısını sayfa sayfa okuyabilmek için Pipe (Boru) operatörü `|` kullanılarak işlem `more` komutuna aktarılmalıdır (Örn: `type devasa_log.txt | more`).

Windows'ta Sistem Bilgilerini Toplama

Bir Windows sistemine ilk erişim (Initial Access) sağlandığında, körleme komut çalıştırmak veya rastgele dizinlerde gezinmek Güvenlik Operasyon Merkezi (SOC) alarmlarını tetikleyecek en büyük amatörlüktür. Sistemin anatomisini çözmek, güvenlik duvarı kurallarını anlamak ve **Privilege Escalation** (Yetki Yükseltme) ile **Lateral Movement** (Yanal Hareket) stratejilerini belirlemek için "Situational Awareness" (Durumsal Farkındalık) aşamasına, yani Sistem Keşfine (System Enumeration) geçilmesi zorunludur.

Operasyonel adımların ilki, sistem üzerinde hangi kullanıcının haklarına ve token (Erişim bileti) bağlamına sahip olduğumuzu doğrulamaktır. Bunun için `whoami` komutu kullanılır.

```
C:\Users\m.scott> whoami
desktop-a1b2c3\m.scott
```

Çıktı bize sadece bir isim vermez; makinenin adını (veya etki alanını) ve kullanıcı adını `DOMAIN\Username` veya `HOSTNAME\Username` formatında sunar. Bu çıktı, sistemdeki okuma/yazma/çalıştırma kapasitemizi belirleyen **ACL (Access Control List - Erişim Kontrol Listesi)** sınırlarının temelidir. Eğer bu komut `nt authority\system` döndürseydi, sistemin mutlak hakimi olduğumuzu anlayacaktık.

ÖNEMLİ: Sadece kullanıcı adını bilmek ileri seviye sızma testleri için yetersizdir. Eğer B Planı olarak, mevcut kullanıcının arka planda sahip olduğu özel izinleri görmek istiyorsak (Örneğin `SeImpersonatePrivilege` gibi doğrudan sistem haklarına sızrama yapmamızı sağlayan kritik yetkiler), komutu `whoami /priv` veya kullanıcının dahil olduğu yerel/domain gruplarını görmek için `whoami /groups` şeklinde genişletmeliyiz.

Sistemin ağ üzerindeki kimliğini ve rolünü tespit etmek için `hostname` komutu çalıştırılır.

```
C:\Users\m.scott> hostname
DESKTOP-A1B2C3
```

Bu komutun teknik karşılığı, özellikle devasa **Active Directory (AD)** ortamlarında hayati önem taşır. Elde edilen `DESKTOP-A1B2C3` gibi bir isim sıradan bir son kullanıcı makinesinde olduğumuzu gösterirken; `DC01` , `EXCH01` veya `FS01` gibi bir çıktı, sırasıyla bir Domain Controller, Exchange Server veya File Server (Dosya Sunucusu) üzerinde olduğumuzu, yani doğrudan kurumun kalbine sızdığımızı gösterir. Hedefin rolü, kullanacağımız saldırı vektörünü tamamen değiştirir.

İşletim sisteminin tam versiyonunu, mimarisini ve en önemlisi eksik yamalarını tespit etmek için Windows'un yerleşik yapılandırma döküm aracı olan `systeminfo` komutu kullanılır.

```
C:\Users\m.scott> systeminfo

Host Name:                DESKTOP-A1B2C3
OS Name:                  Microsoft Windows 10 Pro
OS Version:               10.0.19044 N/A Build 19044
OS Manufacturer:         Microsoft Corporation
OS Configuration:        Standalone Workstation
OS Build Type:             Multiprocessor Free
System Type:              x64-based PC
...
```

Devasa bir çıktı üreten bu komutun ilk bölümü, sistemin DNA'sını içerir.

- **OS Name & Version:** İşletim sisteminin Windows 10 Pro ve Build (Derleme) numarasının 19044 olduğu görülmektedir. Bu bilgi, bu spesifik versiyon için yayınlanmış olan Kernel zafiyetlerini (Örn: PrintNightmare, SeriousSAM) doğrudan Exploit veritabanlarında aratmamızı sağlar.
- **System Type (x64-based PC):** Sistemin 64-bit mimaride çalıştığını kesinleştirir. Sisteme yüklenecek olan Reverse Shell (Ters bağlantı) zararlıları veya belleğe enjekte edilecek Shellcode'lar (Zararlı makine kodları) kesinlikle 64-bit derlenmelidir; aksi takdirde 32-bit (x86) bir payload hata verecek ve çalışmayacaktır.

DİKKAT: `systeminfo` çıktısının en altında yer alan "Hotfix(s)" (Sistem Yamaları) bölümü, yetki yükseltme (LPE) senaryoları için asıl altın madenidir. Sistemde hangi güvenlik güncellemelerinin **yüklü olduğu** listelenir; böylece bir siber güvenlik uzmanı, nelerin eksik olduğunu tersine mühendislik mantığıyla bularak saldırı rotasını çizer.

Mevcut makinenin ağ topolojisindeki yerini, hangi alt ağda (Subnet) bulunduğunu ve dış dünya ile nasıl konuştuğunu anlamak için `ipconfig` komutu çalıştırılır.

```
C:\Users\m.scott> ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:
```

```
Connection-specific DNS Suffix . :  
IPv4 Address. . . . . : 192.168.1.105  
Subnet Mask . . . . . : 255.255.255.0  
Default Gateway . . . . . : 192.168.1.1
```

Çıktının operasyonel analizi şöyledir:

- **IPv4 Address (192.168.1.105):** Makinenin o anki ağdaki yerel adresidir. Dinleme (Listening) yapacağımız portlar veya kuracağımız tüneller bu adrese bağlanacaktır.
- **Default Gateway (192.168.1.1):** Tüm ağ trafiğinin dışarı çıkmak için yönlendirildiği ana kapıdır (Genellikle bir Router veya Firewall). Yanal hareket (Pivoting) operasyonlarında ağdan dışarı sızmak (Exfiltration) veya farklı bir ağ segmentine atlamak için bu IP'nin kuralları aşılmalıdır.

Eğer sistemde bir DNS Spoofing (Alan adı sahtekarlığı) yapılacaksa, DHCP sunucusunun IP'si aranıyorsa veya makinenin fiziksel MAC adresi kopyalanacaksa (MAC Spoofing), standart `ipconfig` yetersiz kalır. Bu gibi durumlarda tüm ağ bağdaştırıcılarının mikroskobik detaylarını görmek için komut `ipconfig /all` şeklinde genişletilerek çalıştırılır.